electronics

MDPI

Article

A Zero-Trust Architecture for Remote Access in Industrial IoT Infrastructures

Fabio Federici †, Davide Martintoni † and Valerio Senni *,†

Applied Research and Technology, Collins Aerospace, 00185 Rome, Italy
* Correspondence: valerio.senni@collins.com
† These authors contributed equally to this work.

Abstract: This paper considers the domain of Industrial Internet of Things (IIoT) infrastructures and the recurring need for collaboration across teams and stakeholders by means of remote access. The paper describes a secure solution beyond the traditional perimeter-based security approach, which consists of an architecture that supports multi-level authorization to achieve fine-grained access control, better scalability, and maintainability. An implementation of the proposed solution, using open-source technologies, is also discussed and covers the protection of both the network and edge domains of a complex IIoT infrastructure. Finally, the paper presents a risk-driven and model-based process that is designed to support the migration of existing infrastructures to the solution architecture. The approach is validated, taking as a reference two relevant scenarios for the aerospace industry.

Keywords: access control; industrial IoT; zero-trust; industrial control systems; connected aircraft

check for updates

Citation: Federici, F.; Martintoni, D.; Senni, V. A Zero-Trust Architecture for Remote Access in Industrial IoT Infrastructures. *Electronics* **2023**, *12*, 566. https://doi.org/10.3390/electronics12030566

Academic Editors: Georgios Kavallieratos, Georgios Spathoulas and Marios Anagnostopoulos

Received: 22 December 2022
Revised: 16 January 2023
Accepted: 17 January 2023
Published: 22 January 2023

Copyright: © 2023 by the authors. Licensee MDPI, Basel, Switzerland. This article is an open access article distributed under the terms and conditions of the Creative Commons Attribution (CC BY) license (https://creativecommons.org/licenses/by/4.0/).

1. Introduction

Industrial Internet of Things (IIoT) and cloud technology [1] are significantly contributing to the data revolution [2], with the effect of enabling novel and more integrated services, end-to-end optimizations, better agility in a changing market, the reduction of risks, improved quality and compliance auditing, the maximization of margins, and more reliable forecasts [3]. One of the key transformations in this context is an easier and more secure collaboration, achieved by breaking a silos-based culture and opening infrastructures to digital integration and data exchange among stakeholders and collaborators in the ecosystem.

A general IIoT reference architecture is proposed in [4] and is applicable to several domains, showing that an IIoT collaboration infrastructure is made of multiple layers, ranging from resource-constrained edge devices (often operating in harsh environments and potentially employing a mix of standardized and proprietary technologies) to more traditional IT corporate networks, including services and technologies for business-level integration. Collaboration itself can happen at different layers, requiring authorization from multiple stakeholders and involving diversified technologies and processes at each layer. The Industrial Internet of Things Trustworthiness framework [5] highlights the complexity of establishing and maintaining trust, the need for managing cyber-security risks as they evolve in time, and the challenges of addressing multiple technical layers across organizations. Currently employed security technologies have some recurring limitations: (1) they are not meant for dynamic reconfiguration, which leads to expensive and error-prone maintenance procedures, (2) they adopt a perimeter-based approach to security so that an actor, once authenticated and inside the perimeter, is not continuously monitored on their operations, and (3) they offer good maturity on the IT domain but struggle with the protection of edge and proprietary technology.

Zero-Trust (ZT) is a consolidated paradigm promoted by the National Institute of Standards and Technology (NIST) in a dedicated Special Publication [6] based on the core

concept of "never trust, always verify". The concept is articulated in several key principles revolving around continuous authentication, rigid access control, least-privileges, monitoring, and segmentation. The standard also offers a few high-level reference architectures for implementing the ZT principles in existing environments. There are a number of challenges in the adoption and migration to a ZT architecture [7,8], one of them being the complexity of security management, as the size of the infrastructure grows (risk evaluations, configurations, and life-cycle change management).

This paper considers two application domains (Manufacturing and Civil Aviation) where the emerging needs of integration, data-sharing, and collaboration are becoming pressing and non-deferrable. The considered scenarios focus on the need for an external subject to access resources in a target domain, as depicted in Figure 1. The problem of remote access to enterprise resources at the edge has been analyzed in Industrial IoT scenarios [9] or in Industrial Control Systems architectures [10,11], often with a reduced focus on security. Pohl et al. [12] provided an assessment of traditional technologies (OpenVPN and IPsec) for remote access to IIoT scenarios. However, this interaction poses several cyber-security threats to the overall infrastructure, such as the possibility for the subject to have their credentials stolen, or to put in place (intended or unintended) malicious behaviors impacting on the target resource security, as well as the security of the entire target domain, or to act as a medium through which malicious payload or malicious actors can gain access to the target domain and leak sensitive data out of it. Traditional perimeter-based security (focused on deploying perimeter controls) cannot easily cope with these threats. This leads to consider as a viable alternative the ZT model, which does not trust an entity based on its location, but always validates, authorizes, and monitors any interaction.

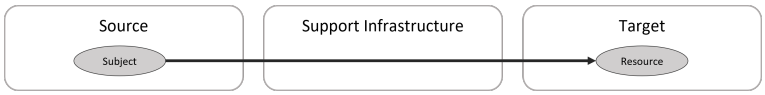

Figure 1. High-level data-flow required for remote access to a resource.

This paper proposes an innovative two-layered access control architecture compliant to the ZT model that is able to address the shortcomings mentioned previously; in particular, through the means of: (1) automated support to dynamic re-configurations, in compliance with an established security policy; (2) end-to-end zero-trust enforcement, with the simplified management of access control policies leveraging a two-stage authorization pattern that is able to achieve fine-grained control on resources, and (3) the coverage of both network and edge domains protection, relying on existing architectural patterns for IT/OT infrastructures and providing security support for legacy and proprietary equipment. Our proposed architecture is integrated with a risk-driven process that supports the migration of existing infrastructures, prioritizing changes where cyber-security risks are identified.

To demonstrate the feasibility of the proposed architecture and to support its validation in realistic environments, a proposed implementation is discussed, and the results of its deployment and evaluation on a real industrial demonstrator are reported. In particular, the proposed implementation is based on two key technologies, which will be further discussed in the rest of the paper:

- Software-Defined Networks (SDN) [13], used at the network level to provide the centralized and programmatic management of the network's configuration and security, which guarantees a separation between decision making and policy enforcement.
- Trusted Execution Environments (TEE) [14], used at the edge to protect sensitive assets (data, functions, services, and I/O) from untrusted components in the same computing platform, ensuring their confidentiality, integrity, and trusted use.

This paper is organized as follows. Section 2 discusses the related works. Section 3 describes two motivating scenarios and extracts from them a set of common needs, threats, and high-level requirements. Section 4 presents the solution architecture and proposes a risk-driven process to migrate existing infrastructures to it. Section 5 describes a possible

implementation for the solution architecture and discusses its validation in a demonstrator, as well as with respect to the identified security requirements. Finally, Section 6 summarizes future directions to improve this work, and expands the research on currently open topics.

2. Related Work

In [15], the authors, similarly to the approach proposed in this paper, leverage SDN to centrally control data paths, proposing a dynamic authorization technology based on user trust profiling. This dynamic aspect of the TA enables the run-time reconfiguration of data paths. The principal differences with the proposed solution are that (i) the proposed approach covers edge protection, with the capability for enforcing precise fine-grained access control on endpoint resources, and (ii) this research proposes an implementation architecture and a methodology supporting migration and maintenance along the life-cycle.

The work presented in [16] shares several commonalities with the current work, for what concerns the use of SDN for network domain security and access control. However, the solution proposed in this paper is able to provide a very fine-grained degree of access control on IoT resources (at the level of the memory region or single peripheral). Another difference is the ability to continuously assess authorization and to validate behaviors, supported by the underlying zero-trust concept, and enabled by the way in which selected technologies (SDN and TEE) have been integrated. One area of improvement for the current work is the evaluation of the performance, both in terms of throughput and in terms of energy efficiency. This is an opportunity for improvement, where a comparison with the cited work can help to establish a proper evaluation approach.

In [17], the authors perform a deep-dive investigation on micro-segmentation approaches, proposing a workflow-level isolation approach to minimize lateral movement, and a metric to evaluate the trade-offs between efficiency and achieved security. It would be interesting to apply those metrics to the proposed methodology to offer live feedback to designers on multiple quality factors of the defined architecture and support exploration for optimal trade-offs.

In the 5GZORRO project, the challenge of security on multi-domain and multi-stakeholder scenarios on 5G networks is addressed. In these scenarios, the zero-touch management of endpoints is of core importance. To address integrity, non-repudiation, confidentiality, security, and trust requirements, they rely on several security technologies, among which is a TEE-based Security Management service [18]. An in-depth analysis of that work to assess commonalities and potential synergies will be our future work, after performing a mapping of the reference scenarios with their ecosystem, which is different for a number of reasons.

In [19], the authors investigate the field of multidisciplinary early design risk assessment, considering joint safety and security considerations based on a common model, which supports the accurate estimation of the probability of successful attacks on system components. The concept of Zero Trust is central in that paper, driving the entire risk evaluation approach. Interestingly, they underline that joint safety and security assessments provide more informative and accurate predictions. Considering the scenarios analyzed in this paper, it would be interesting to include explicit safety considerations into the proposed methodology. For the moment, for scenarios concerning the Civil Aviation sector, the reference is the methodology established in [20].

Teerakanok et al. in [7] analyze the challenges of migrating from a legacy architecture to a ZTA, mostly from an IT infrastructure perspective. In the current work, a solution to some of those challenges is proposed, relying on a model-driven methodology.

3. Application Scenarios

This section describes two application scenarios from different sectors, providing cyber-security needs and architectural constraints to guide the design of the proposed architecture as a reusable solution.

3.1. Secure Remote Maintenance for Industry 4.0

This scenario is driven by the increased need for automation, connectivity, and data collection in modern manufacturing processes. Industry 4.0 (I4.0) [21] is a recent industrial trend where the manufacturing process at the edge is integrated vertically with the corporate network infrastructure, and horizontally with third party service providers, in order to drive an optimized and sustainable production for higher business performance. One of the recurring needs is the availability of a robust and trustworthy remote access functionality, supporting services such as data collection, monitoring, and remote maintenance. Remote access facilitates operations, reduces downtime and costs, and minimizes the risks of sensitive information disclosure.

Remote access can be formulated as a data-flow from a source domain (the service provider) to a target domain (the edge device subject to maintenance) through a support infrastructure (public internet and corporate network). These are different security domains with specific levels of trust and security controls. The crossing of different security domains require stringent controls to guarantee authorization, least privilege access, no information leakage, and the protection of services and equipment. Therefore, the architecture and services offering remote access shall be protected with the highest security measures, ensuring the confidentiality, integrity, and availability of the industrial operations.

Figure 2 provides a conceptual representation of the remote maintenance scenario, where a remote maintainer is identified and can access industrial equipment located in a factory plant. The support infrastructure includes the public internet, third-party cloud services, the corporate network, and the edge networks, integrated by using industrial gateways. We consider multi-plant scenarios where both modern and legacy equipment have to be managed securely while being subject to remote maintenance operations. Besides this primary need, there are also additional needs to be considered and that pose additional constraints. In particular, in parallel with maintenance operations, there are data feed and data collection operations that require the treatment of sensitive manufacturing data (design, performance, and compliance), that shall not be leaked to the maintenance service provider.

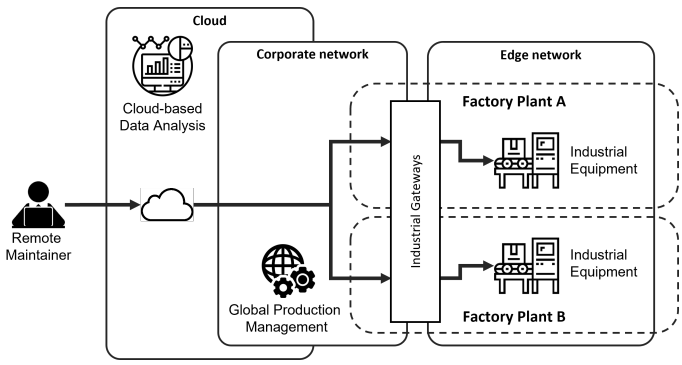

Figure 2. Secure Remote Maintenance Scenario.

In terms of security policies and requirements, the maintainer shall access only the minimum amount of data and services for the minimum required time, thus providing confidentiality guarantees for the data in transit, in use, and at rest. On the other side, the solution shall provide adequate protection for the availability and integrity aspects related to the manufacturing operations.

3.2. Connected Aircraft

Air transportation is experiencing a deep transformation, due to the compelling needs for optimizing the efficiency of travel (both from the perspectives of operations and of energy consumption) [22] and improving customer experience (with reduced times and more customized services) [23]. Maintenance is one of the critical activities where the safety of the flight shall be continuously guaranteed, while aircraft "ground-time" shall be

minimized [22,24]. The transition to an IoT paradigm, where the systems and components are connected, remotely accessible, highly configurable, and supporting the continuous collection of data relevant for maintenance and optimization, can play a disruptive role in terms of services and cost reductions. In this context of growing connectivity and digitization, cyber-security has been a central topic in Civil Aviation for decades. More and more stringent regulations have been defined to deal with the evolution of networking and computation technologies, and cyber-security has been recognized as one of the key requirements for airworthiness [20].

An overview of this scenario, where we consider connected cabin systems, is illustrated in Figure 3. Cabin interiors (lavatories, seating, cooking inserts, and lighting) are replaceable aircraft sub-systems and components with a growing element of embedded intelligence, as well as their own sub-networks. They are becoming equipped with wired and wireless sensors and actuators that support services for a better user experience, increased hygiene, and airline-driven customization. These systems and components are connected to the airplane service network, with their connectivity routed out of the airplane, to expose their services interfaces for digital interaction with multiple stakeholders (airline, aircraft integrator, product owner, or airplane maintainer), depending on the specific application needs. In addition, cabin systems and components are physically accessed, during operations, by passengers and flight attendants, through their HMI, as well as by maintenance operators, during any maintenance activity. External connectivity for health monitoring [25] or data-load [26] operations may be provided by means of an Aircraft Gateway device, offering a bridge between the external environment and aircraft systems.

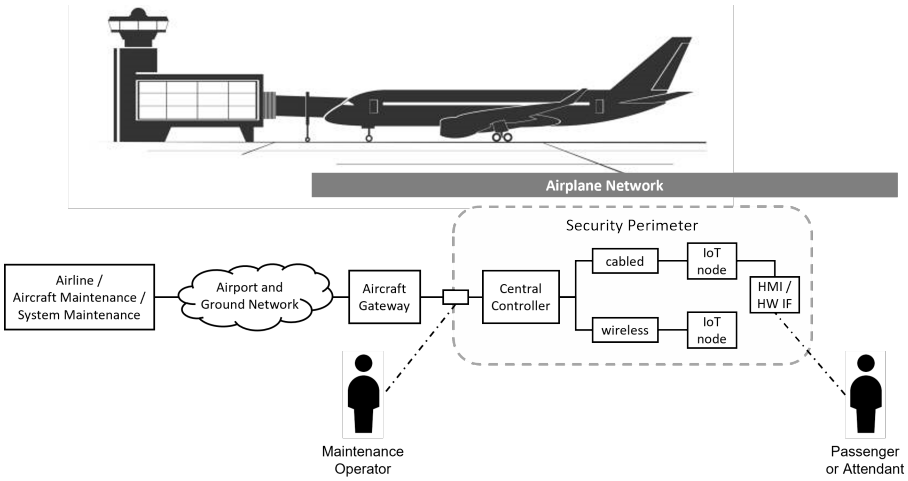

Figure 3. Connected Aircraft Scenario.

The scenario can be divided in three principal functional interactions. First, the need to reach the airborne systems for normal operations, including the customization required by the airline operator, such as branding or specific settings for their flight needs. Second, the need to reach the airborne systems for maintenance (including patches and updates), prognostics, and health monitoring. Third, the need to reach the airborne systems to provide remote support for integration, replacement, and general support to ground operations to reduce service disruption time.

In terms of security policies and requirements, the first interaction is principally subject to confidentiality and privacy requirements, due to the potential handling of sensitive data related to the identities of passengers. The second, instead, is primarily subject to integrity requirements for the protection of software payloads (and, consequently, of systems integrity) as well as of health monitoring data. The third, finally, is primarily subject to availability requirements, together with some confidentiality aspects related to the treatment of IP-sensitive data of the system design/operation.

3.3. Threats and Common Security Requirements

This sub-section considers the kind of attacker that the application scenarios are subject to, and provides a summary set of security requirements to guide the design of the proposed solution. Following the approach of [27], it is possible to define the main characteristics of the attacker and derive, from them, the desired security level. In terms of profile, the considered attackers are either *insiders* (interested into exploiting their specific privileges to damage the company or leak sensitive data) or *cyber-criminals* (well-equipped professionals with interests in industrial espionage or extortion). Some key dimensions can help to differentiate the two profiles: knowledge and available tools, distance (or accessibility), targets, and motivations. In terms of knowledge, the insider has greater visibility in the system architecture, configurations, protocols, and procedures, which poses a challenge for enforcing automated controls and procedures, or resorting to multi-actor authorization processes. Similarly, they also has a greater advantage in terms of accessibility, which poses a challenge to the protection of interface and of legacy equipment. Their motivations are often bound to anger or dissatisfaction, and they targets service disruptions to damage the company. Less frequently, their targets are also bound to sensitive information leakage. On the other side, cyber-criminals have a deep knowledge of vulnerabilities and can leverage non-conventional tools for their advantage. In addition, they are very motivated, are capable of sophisticated camouflage strategies, and they target the disclosure of sensitive information.

The scenarios of Section 3 have a recurrent template matching the target architecture illustrated in Figure 4, where the subjects from a source domain require access to one or more resources within a target domain. In both scenarios, the resources are sensitive and they require fine-grained access control. Another commonality is that the target domain is usually reachable by the subjects through the exploitation of services exposed by a support infrastructure.

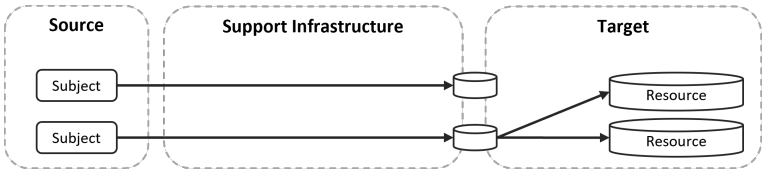

Figure 4. Target Architecture.

On this common target architecture, a security threat analysis is performed using the STRIDE methodology [28] to identify the most relevant threats to the target resource and to the overall target domain. The results of this analysis are summarized in Table 1.

The threat analysis highlights some common security threats that concern all of the scenarios discussed previously. To mitigate the risk posed by this list of threats, a list of common security requirements is also derived:

SR1: The solution shall enforce least knowledge and least privilege principles through a strict access control, ensuring the confidentiality and integrity of the resource.
SR2: The solution shall guarantee that the system is resilient to denial-of-service attacks by providing a distributed and layered security approach.
SR3: The solution shall provide fine-grained access control, ensuring that a subject can access a resource only if it is specifically authorized to do so.
SR4: The solution shall provide robust logging guarantees, ensuring that a subject is properly traced at all times while accessing a resource.

To provide a solution that would fit the scenarios presented so far, all of the security requirements should be addressed at design time by the proposed solution architecture.

Table 1. STRIDE-based Threat Analysis.

Threat Type	Description	Effect
Spoofing	Subject reads data without authorization on the target resource	Data confidentiality of the resource is compromised
Tampering	Subject perform unauthorized changes on the target resource	Integrity of the resource and related assets is compromised
Denial of Service	Subject overflows the system with service requests	Target resource (and possibly, the entire target domain) is not available
Information disclosure and Elevation of Privileges	Coarse grained or inconsistent security policies allow unauthorized access	Once authorized in the target domain, a subject can perform lateral movement to reach other resources
Repudiation	Poor logging capabilities miss tracking of malicious activity	Subject not accountable for its actions in the target domain

4. Proposed Solution

The Zero-Trust Architecture has been introduced [29]. This model removes the distinction between the internal and external networks (and along with that, the concept of implicit trust for objects in the internal network), promoting the verification and securing of all resources, the strict enforcement of access control, and the inspection and log of all network traffic. According to the basic tenets defined by NIST, in a Zero-Trust Architecture, all data sources and computing services are considered as resources and all communication is secured, regardless of the network location. No asset is inherently trusted: the enterprise infrastructure is responsible for the monitoring and measurement of the integrity and security posture of all associated assets. Furthermore, authentication and authorization are strictly enforced before access is allowed to any resource. Access is granted on a per-session basis and is determined via dynamic policies.

The standard provides the description of a generic architecture implementing the Zero-Trust principles, which identifies two principal components: (i) a Policy Engine, making the decision to grant, deny, or revoke access to a resource, and (ii) a Policy Administrator, executing the decision by establishing or refusing communication between the parties. In particular, the access to a resource by a subject is mediated by the Policy Enforcement Point (PEP), which is responsible for enabling or refusing the connection. The decision to grant, deny, or revoke the access to the resource is taken by the Policy Engine (PE) and executed by a Policy Administrator (PA), which establishes or refuses the communication path based on the PDE decisions. The trust algorithm (TA) is the process used by the Policy Engine to ultimately grant or deny access to a resource. The Policy Engine takes input from multiple sources (the policy database with observable information about subjects, subject attributes and roles, historical subject behavior patterns, threat intelligence sources, and other metadata sources). It should be noted that in this view, the PEP constitutes the data path between the subject and the resource, while the PE and the PA operate in the control plane, implementing a so-called Policy Decision Point (PDP).

As discussed, the notion of Zero Trust requires that each point-to-point interaction is subject to a set of security measures (Authentication, Access Control, and Trust Evaluation) to guarantee that the counterpart is properly authorized. However, in practice, what can be seen as a point-to-point interaction depends on what is considered as an "atomic" component, and it is related to the established level of abstraction. Refinement can lead easily to the decomposition of an atomic component into a more complex architecture. As an example, consider the network nodes and network links as the atomic elements of the reasoning around ZT. This simplified domain raises a lot of questions that are related to the trust of intermediate network equipment, such as firewalls, gateways, and even

simple switches. Looking inside network nodes, instead, it is possible to find an even larger domain of reasoning, related to platform layers (board, OS, middleware, applications, services, etc.).

The solution proposed in this paper in Figure 5 is structured into two layers (network and edge) and adopts two different levels of abstraction. The choice of the layers is performed in accordance with the recurrent pattern of IT/OT infrastructures [4,30,31], where the traditional IT infrastructures are interfaced with networks of embedded devices and control systems at the edge, for domain-specific tasks. The two layers are treated at different levels of abstraction, for what pertains the ZT concept. The network part is abstracted at the levels of the nodes, firewalls, gateways, and services. Ignoring all of the security aspects related to the software/services deployment, configuration, integration, and operation is motivated by the fact that the area is well understood and was, originally, the primary focus of ZT; therefore, it is possible to inherit all of those best practices. The realization of the ZT concept at the edge, instead, is much less well investigated for several reasons [32]: (i) a lack of standardization in both the infrastructure and the software, (ii) a heterogeneity of computing resources and a (lack of) openness of the edge equipment platforms, (iii) the complexity to retrofit existing legacy, primarily for the required level of investment, and (iv) the existence of stringent sector-specific regulations (most prominently, those related to safety). The proposed solution leverages two emerging concepts in the edge realm to realize an innovative ZT approach and to address the problem in a more structured manner. The first concept (well established in the Industrial IoT domain) is that of the Industrial Gateway [33], which is a node sitting at the boundary between the IT and the OT domains, responsible for mediation between domain-specific technologies (networks, services, and protocols) and standard business/engineering infrastructures. The Industrial Gateway is increasingly being used as a trusted node for deploying security measures, and it can act as a Policy Decision or Enforcement Point (compare with the Gateway Portal Model of NIST SP 800-207 [6]). The second emerging concept is the standardized pattern of TEE [14,34], which is able to provide confidentiality and integrity guarantees on sensitive data and software in the context of a rich (and untrusted) execution environment, reducing to the minimum the size of its trusted computing base (i.e., the amount of software and hardware to be trusted for the protection of sensitive data and software). TEEs can allocate processor time, regions of memory, and platform peripherals to an executing service, with guarantees of isolation from other software in execution, including (a degree of) independence from the guest OS.

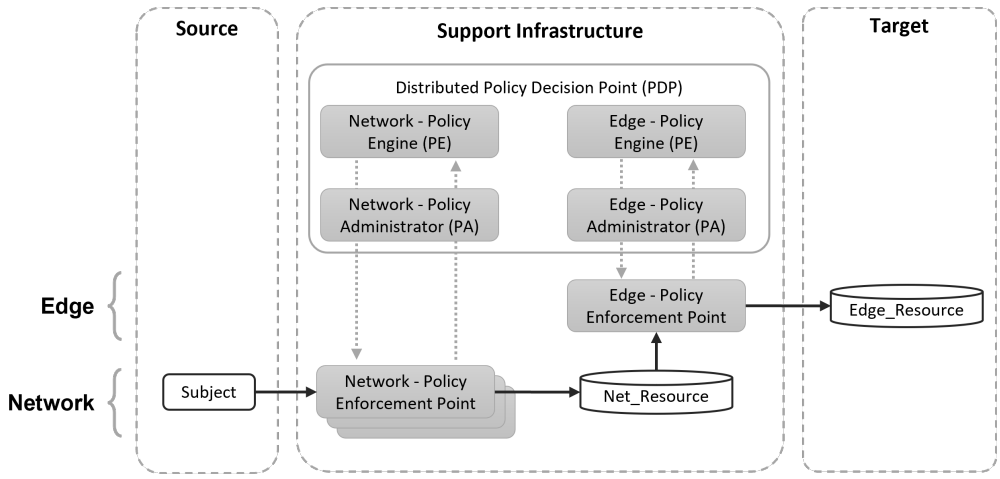

Figure 5. Two-layered Zero-Trust Solution Architecture.

The novel idea of the proposed Two-layered Zero-Trust Architecture is to realize the end-to-end security controls in two stages: one is responsible for the networking part, managing the access to the services at the edge, while the other is responsible for access

on the edge resource. They act at different levels of granularity, and this mix is fruitful for several reasons: (i) managing the complexity of realization of the ZT in an end-to-end infrastructure, (ii) managing the security controls at different granularity, on a per-need basis, (iii) supporting technology heterogeneity and legacy, (iv) integrating with vendor-closed solutions. Notice that the two-layered design is devised to sustain a Zero-Trust approach in an existing infrastructure where security services at the network level are already in place. In this context, the edge device is completely agnostic of the security controls deployed at the network level.

Figure 5 illustrates a Subject in the untrusted domain that wants to access a Resource in the target domain (black arrows from left to right). The ZT template is applied here in two stages. The first stage regulates access to an intermediate resource (Net_Resource at the boundary of the target domain) that acts as a mediator for a set of resources (not necessarily all) in the target domain, illustrated as Edge_Resources. In the second stage, the mediation resource (Net_Resource) has a role of regulating access to the target resource (Edge_Resources), with a finer-grained resolution (e.g., regulating data access). Therefore, in the second stage, the ZT concept is applied between the original Subject and the target Resource, with the Net_Resource acting as a PDE/PDP. Concerning the PA, it would be desirable to have a single PA coordinating all of the PDE/PDP. How this can be realized is discussed in the following sections of the paper.

The adoption of the proposed approach to implement a remote access functionality provides the following advantages:

1. The solution decomposes the complexity of end-to-end by handling network security and edge security separately. Separation allows for better focusing on domain-specific solutions, as pointed out in Section 5. In addition, it enables easier adaptation to different Support Infrastructure needs.
2. The architecture can manage different granularities in terms of security controls: the first stage essentially focuses on controls at the level of the services hosted on a network node, while the second stage controls the access to node resources (memory, data, peripherals, and I/O), relaxing the assumption that the whole node is trusted (which is often not realistic). On the contrary, approaching the security controls of the entire end-to-end chain at the same accuracy level would pose scalability challenges.
3. While the IT networking domain has an established degree of standardization, the IoT/edge is still an ambiguous domain. For this reason, the introduction of an intermediate resource can support the aggregation of technologies, manage customization for the specific domain, or comply to sector-specific regulations. An intermediate resource can play roles that range from hosting all of the security functions for an otherwise unprotected legacy/closed/proprietary edge device, to performing the secure routing of authorized service requests to the requested edge nodes. Therefore, the intermediate resource between two different security ecosystems ensures the consistency of the overall end-to-end security solution.
4. By introducing multiple intermediate resource mediators, it is possible to implement micro-segmentation. Therefore, through appropriate design, it is possible to mitigate for lateral movement risks threatening other resources that are out of the scope of the mediator. These characteristics are a unique focal point of the proposed solution: they enable control over the granularity of the ZT enforcement. A similar argument can be made for what concerns security incidents and related operational disruptions (therefore, bringing a contribution to infrastructure resilience), where the impact can be controlled by the careful choice of the number and the role of the mediators.
5. The proposed solution facilitates maintainability, since an intermediate resource mediator hides the managed endpoints, which can be replaced and reconfigured in time (as frequently experienced in manufacturing domains).
6. The proposed solution architecture is adequate for the protection of legacy equipment, extends the solution presented in [35], and implements good practices and guidelines as summarized therein.

4.1. The Migration and Integration Process

Teerakanok et al. in [7] correctly identify several open challenges for the effective deployment and integration of a ZTA: (i) compatibility and interoperability (covering multiple technologies, data formats, and security solutions), (ii) the global visibility of resources and their associated levels of trust, (iii) change management, capable of handling the implemented security concept in its life-cycle, and (iv) the consistency, accuracy, and comprehensiveness of the adopted Trust Algorithms. They also identify three steps for facilitating migration: (a) the assessment of high-value assets and value processes, (b) the evaluation and prioritization of risks, and (c) the incremental deployment of security mitigation, with a measurement of effectiveness.

In this section, we describe a novel approach to support transitioning to ZTA in a risk-driven manner. This approach is detailed in a recent paper [36] for a different application purpose. The proposed methodology (i) combines the design of digital manufacturing infrastructures with their security risk assessment by identifying current threats and evaluating the level of risk associated with them, (ii) supports the identification of mitigation to the identified security threats, (iii) helps with tracing the security elements to the architectural components that they relate to, and (iv) guides the implementation of security measures, with a focus on the protection of remotely accessible endpoints. This work explicitly addresses the most relevant open challenges summarized previously. As a first step, the proposed approach leverages model-based representations of architectures to analyze the assets, information flows, and security policies, support the identification of weaknesses, quantify their induced risks, and propose mitigation for the unacceptable ones. Mitigation induces new security requirements and their allocation to elements of the architecture. The fulfillment of the new security requirements is then supported by providing guidance and best practices for the addition of Architectural Patterns (i.e., architectural solutions for the enforcement of security properties) and the use of Security Building Blocks (i.e., SW/HW implementation solutions that can be used to realize specific security functions).

In [36], the adopted Architectural Pattern was based on an industrial gateway placed at the IT/OT edge, and was used to enforce the separation of information flows targeting legacy endpoint equipment. Additional SW, deployed in the industrial gateway and relying on hardware-enforced isolation primitives, provides the Security Building Blocks required to protect edge components and their data during remote maintenance activities.

This research expands that initial idea to a broader scope, and proposes, as a more comprehensive Architectural Pattern, the Two-layered Zero-Trust Solution Architecture discussed in Section 4. Specifically, the proposed methodology focuses on the objective of supporting the consistent, accurate, and comprehensive configuration of the Trust Algorithm governing the PE. The Trust Algorithm drives the decisions to authorize or to deny any access request. The decision is taken based on several elements, retrieved from different sources that are either "architecture driven" (such as source Subject, destination Resource, host device, established access control policies, and security configurations) or "dynamic" (such as network traffic, threat intelligence, and activity logs). One additional complexity is the consistent configuration of the PDPs in charge of coordinating multiple PEPs, implemented with hybrid technologies, as depicted in Figure 5.

Figure 6 provides a representation of the proposed methodology. The overall objective is the improvement of the Current Architecture to achieve a final Secured Architecture, where appropriate Security Measures have been integrated. This improvement may require a few iterations to achieve the desired level of risk reduction, with all the appropriate mitigations in place.

The initial version of the Current Architecture is provided through a formal architecture model based on System Modeling Language (SysML), responsible for providing an abstract description of the system in terms of main components, actors, boundaries, interfaces, and information flows. The process required for eliciting the Security Measures proceeds in three steps: (i) the identification of Threat Scenarios, (ii) the Evaluation of Risks

and consequent ranking, and finally (iii) the identification of Risk Mitigation in terms of the requirements attached to the architecture.

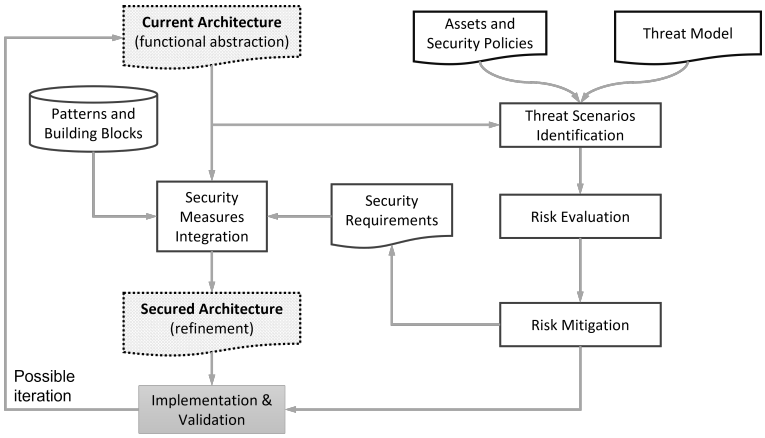

Figure 6. Migration and Integration Methodology.

Threat Scenarios are essential elements of the analysis, as they represent possible interactions and propagation paths that a malicious actor in the system can exploit to achieve (unauthorized) access to the assets. Threat Scenarios are used to identify what architectural elements are involved in a potential attack and support the identification of services, interfaces, and resources that require protection according to Zero-Trust principles. The use of a model, in this step, provides a formal support that improves the consistency, accuracy, and comprehensiveness via the exhaustive elicitation of architecture elements, as well as hidden or undocumented assumptions.

The Risk Evaluation has the objective of determining the feasibility of a security event (consisting of the degradation or loss of an asset). In this step, the availability of formal Threat Scenarios improves the objectivity in the evaluation. Threat Scenarios are aggregated by impacted asset, and they are considered in the complexity of execution, as well as for the identification of enabling/common causes (e.g., the vulnerabilities exploited in multiple scenarios, whose mitigations would be effective in reducing the cyber-risk at scale). These are aspects pertaining to the "architecture driven" decision elements of a TA. However, this step also facilitates the elicitation of implicit assumptions, by formally defining the criteria of the feasibility and impact of an attack. These assumptions shall drive the design and deployment of monitoring services, supporting the "dynamic" aspect, that are responsible for assessing whether the assumptions for risk evaluation are confirmed (or negated) as the system is observed during operations. The violation of security assumptions, caused by the below-threshold trust indicators computed at run-time, shall cause (in the short term) immediate response plans and (in the long term) iterations on the methodology to improve the security posture of the infrastructure, after a root-cause-analysis of the unexpected events.

The introduction of Risk Mitigation is driven by specific Architectural Patterns and is derived by the Two-layered Zero-Trust Solution Architecture discussed in Section 4. A selection of these more-specific patterns is reported in the following: (a) the aggregation of equipment by the security domain, behind a PEP realized through a Secure Gateway, (b) the micro-segmentation of services under different PEPs for improving resilience and availability, (c) the micro-segmentation of data, functions, peripherals, or interfaces on the same equipment by security domains, (d) a time-limited remote access tunnel with activity-based authorization, or a specific target set of services, data, or functions, and (e) the coexistence and separation of services at different levels of security in the same equipment (e.g., safety critical controls parameters tuning, PHM data collection, ...). There can be several others, based on variant instances of the original solution architecture. Mitigation is represented, in the model, by fictitious components and by security requirements

attached to existing or newly introduced components; both are available as library elements as SysML security extensions that allow for customization to the application domain. As discussed, the consequence of this partial re-design and re-integration activity is the reorganization of the information flows, the introduction of additional (security) functions, and the encapsulation of existing ones in a protected context. This enriched architecture is identified as the Secured Architecture, and drives the actual implementation. The selection of appropriate mitigation patterns is driven by the experience of the architect, but it can also be directed by company- or sector-specific guidelines and best practices.

In [36] is shown a restricted example of this re-design, applied to the functions and information flows hosted on an industrial gateway, which was (for the purpose of Risk Mitigation) repurposed to a Secure Gateway. In that context is also extended the role of the modeling tool to support implementation envisioning automatic code generation capabilities based on existing and reusable code patterns (called Security Building Blocks in the mentioned paper) for the ARM TrustZone services and the specific modeled functions. Code generation can be extended to include the auto-generation of reconfiguration rules for the Control Layer of the SDN architecture. In this vision, where both ARM TrustZone and SDN PA/PE are configured from a common model and with an automated feature, the overall consistency of security policies is increased, the maintenance effort reduced, and the security addressed as an end-to-end process.

Here follows a summary of the advantages brought about by this model-driven process:

1. The model itself provides an abstract view of the system, which supports separation from vendor- or technology-specific characteristics and working at different abstraction levels [37].
2. The model provides the capability to have a global view on security mitigation and policies in place, overcoming the problem of knowledge sharing in complex, multi-tenant infrastructures.
3. The model supports the elicitation of security assumptions and the documentation of actual security mitigation, thus favoring documentation, the sharing of knowledge, and the definition of monitoring objectives (detecting violations of assumptions).
4. The methodology provides traceability across documented threats, risks, and mitigation, facilitating change management and continuous assessment (e.g., any notified changed in the threat environment can trigger a reassessment)
5. The methodology supports focusing on the most relevant risks first, thus guiding the introduction of ZT principles in an educated manner, with appropriate justifications for the investments.
6. The models can guide configuration activities and can be used as a "single source of truth", reducing misconfigurations introduced by human or process errors.

In perspective, this paper mentioned the opportunity (not entirely available, currently) of the auto-generation of PA/PE configurations from the model. Furthermore, there is an opportunity to automate some of the tasks, related to the Threat Scenarios Identification and Risk Evaluation steps. Formal and automated analyses of the models are possible, as envisioned in [38], which would bring significant reductions of cost, the improvement of accuracy, and the capability to re-execute analyses on need, after changing some parts of the model. Finally, there is a longer-term opportunity that is enabled by models to facilitate accurate and formal communication among stakeholders that are in charge of managing a complex infrastructure [39].

5. Implementation

The proposed Solution Architecture is demonstrated through a prototype implementation, represented in Figure 7, developed for testing and evaluation purposes. The prototype is meant to support a feasibility analysis as well as a technology maturity assessment: the tools selected for the prototype may be replaced in the future with different technologies for improved features, better performance, or increased robustness. The prototype created

for the solution demonstration and evaluation targets the Industry 4.0-inspired remote maintenance scenario presented in Section 3.1, but it also provides a good means to show feasibility for the other application scenario presented. The implementation and demonstration prototype was developed in the context of the COLLABS EU project [40], and deployed on an existing demonstrator reproducing a real manufacturing infrastructure, as described in Figure 2. Before illustrating the prototype, a brief summary of the demonstrator setup is provided. There are four network segments (public internet, enterprise, manufacturing, and shop floor), separated by firewalls/routers, around 40 network nodes (between services and equipment), several IoT sensors, the primary IT/enterprise services, and several dedicated services for the integration of engineering and the management of manufacturing operations.

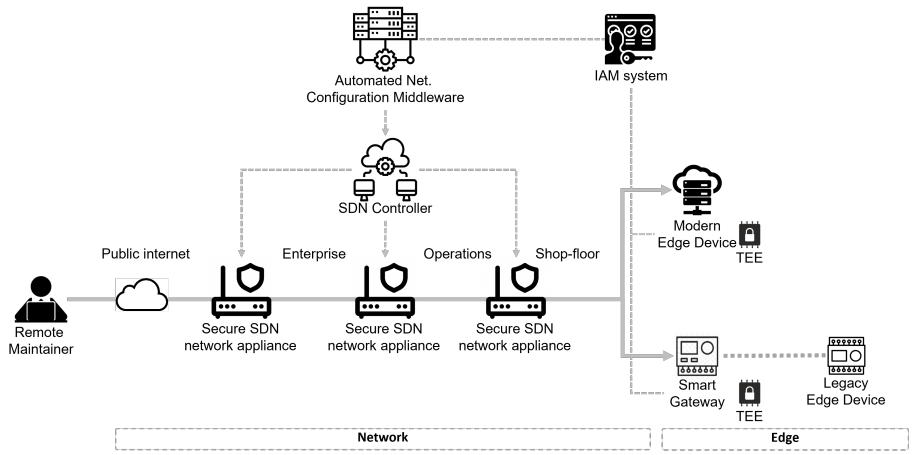

Figure 7. Prototype architecture.

The prototype can be divided in two different layers, one for network security controls and another for edge security controls, in a direct mapping with the general solution proposed in Section 4. The figure represents also a remote maintainer attempting a remote connection to an edge device in the shop floor. Any request for access to a resource must be treated according to the Zero-Trust principles before any type of access is granted.

5.1. Network

As anticipated, the network domain is managed by an SDN platform, which can be organized into three layers: (i) a Data Layer composed by network devices that enforce the network rules, (ii) a Control Layer that manages the network configuration, and (iii) an Application Layer that provides API abstractions to reconfigure and to continuously monitor the network in a programmatic fashion. Figure 8 provides an explicit mapping of the SDN platform layers to the concepts of the proposed solution. In particular, the Data Layer acts as a PEP, the Control Layer acts as a PDP, and the Application Layer hosts the Trust Algorithm (TA), leveraging data collected from Data Layer appliances acting as a distributed network monitoring infrastructure.

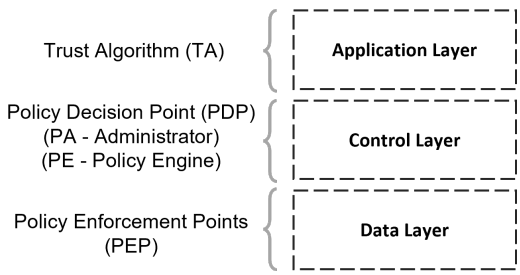

Figure 8. SDN Platform mapping to Zero-Trust concepts.

The Control Layer of the prototype is implemented using an OpenFloodlight SDN controller [41], an open source SDN controller which manages information flows in an SDN-enabled network. This specific controller exposes REST APIs as Northbound APIs, and communicates to the Data Layer with its Southbound API using the OpenFlow protocol. The Data Layer of the prototype is implemented, exploiting OpenVirtualSwitch [42] devices that are SDN-enabled virtual network devices providing switching and routing capabilities. Figure 7 shows that the system deploys an Identity and Access Management (IAM) system, used to enforces specific authorization processes, coordinate authorizing actors, and provide authorizations on access requests. Whether the IAM system is hosted inside the corporate network or in the open internet should not be considered as relevant. According to Zero-Trust principles, IAM services must be always verified and confirmed, regardless of their logical location. A possible approach to the implementation of a distributed IAM function, with the addition of blockchain technologies for trusted transactions, is presented in [43].

The SDN platform receives an authorization token from the IAM on its Nothbound APIs, with a set of desired configuration parameters, which is used to reconfigure the network to allow for remote access to the targeted equipment. This automation in the authorization and reconfiguration process ensures that the network is automatically configured based on authorization tokens, avoiding misconfigurations due to human errors, and also allowing for automatic reversion to the original configurations one that the remote access has terminated. Automation allows for the realization of dynamic security rules that are centrally managed and enforced with a fine-grained granularity at the level of the single network node.

5.2. Edge

In the proposed scenario, any unintended access to the Resource Cluster by an external subject must be avoided. To this aim, specific access control and protection mechanisms for the interaction with the edge device resources should be in place, supervising both the use of I/O interfaces (by means of a PEP) and the functional interaction between the subject and the resources (by means of specific policies, whose enforcement can be delegated to the PE/PA component).

The edge protection is realized through a TEE capability, as shown in Figure 7, with the specific goal of supporting fine-grained access control to the available resources on the edge node (memory regions, peripherals, and trusted functions). Specifically, the TEE is leveraged to isolate and to protect sensitive assets from unintended interaction with parallel information flows (from different parties and with different privileges) within the same edge node, thus reducing the possibilities of information leakage or lateral movement. The edge portion of the system leverages the Gateway Portal model to enforce the Zero-Trust principle. This is also convenient for legacy systems, which would not be capable of self-protection. Note that an extreme case of this scenario would be to host the gateway and related security capabilities on the edge device itself. This approach would enable fine-grained segmentation, but this would be realizable only on modern TEE-equipped smart devices.

Figure 9 revisits the generic model of the Gateway Portal deployment approach, already illustrated in Section 4, detailing the specific implementation for the system under analysis. As anticipated, a Gateway unit acts as an intermediate access point between the Enterprise Network and the Edge portion of the system, modeled as a Resource Enclave containing multiple industrial endpoints. The Gateway leverages an isolated TEE to protects critical functions and assets. The REE is instead used to host all of the other functions, and in particular, the Portal operating logic. The following components support the interaction with external users:

- Web Front-end: offering a user-interface to a managed device.
- Core Logic Back-end: implementing the Portal operating logic and supporting interaction with security-related functions (PE/PA, and PEP).

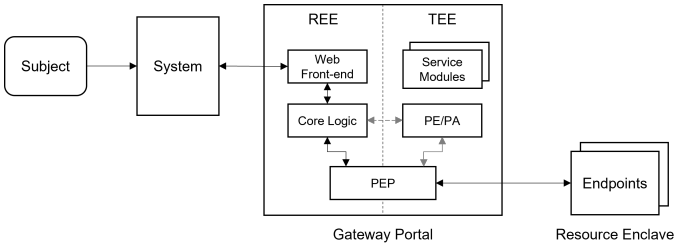

Figure 9. Gateway portal model applied to the Edge section.

The Web Front-end is implemented using the Node-RED JavaScript framework, and it provides a dedicated API to the low-level back-end functionalities. An optional Graphic Interface access is also provided. The Core Logic Back-end is implemented as a standard Linux executable. The TEE hosts the PE/PA logic as a protected isolated function to guarantee its integrity, so that security policies enforcement cannot be bypassed. This component is in charge of interacting with the Portal Core Logic and the PEP function in order to supervise access to critical assets. On the TEE side, other service modules implementing additional services (Trusted Storage and Security Monitoring) may also be included. On the REE side, the Portal Core Logic makes use of TEE support at the OS level (TEE driver and run-time) to interact with the PE/PA on the TEE side. The external subject may be granted permission to access the Gateway Portal, based on the flow detailed in Section 4. The Portal API allows the external subject to push requests to the connected resources (endpoints). The Web Portal receives the requests and forwards them to the Core logic function. The Core logic function interacts with the PE/PA:

- To validate the request: each refers to a specific endpoint in the protected resource cluster and specifies an action to be performed (for example, reading or writing in a certain area of the endpoint memory corresponding to a certain parameter). This request is checked to guarantee that it is not violating the reference security policies.
- To grant access to the target resource: once the request has been analyzed and identified as being legitimate, the path to the resource is enabled by leveraging one of the PEP implementations previously explained.

The proposed implementation adopts the Siemens Simatic IoT2050 as the reference industrial gateway. This module is based on an ARM-v8 System on Chip supporting the Arm TrustZone framework, which has been selected as the underlying TEE supporting technology. The TrustZone, consisting of a set of IP cores deployed at the micro-architectural level and the related supporting software, allowing for the development of a partitioning-based security architecture [44]. Such a framework divides the resources of the system into two distinct domains: the Secure World (TEE) and the Normal World (REE). Each world can execute a different run-time or operating system, with different privilege levels (EL0–EL2) independently supported, and with resources statically assigned to each world. The highest privilege level supported by ARM architecture (EL3) usually hosts the so-called Arm Trusted Firmware (ATF) [45], managing the context switch between the two worlds.

The open-source OP-TEE framework [46] is instead adopted as the supporting firmware/software layer. OP-TEE supports the implementation of a TEE on top of Arm TrustZone for the ARM Cortex-A family, and provides an implementation of the GlobalPlatform API [34]. Figure 10 represents a high-level architecture of the OP-TEE framework on top of the Arm TrustZone partitioning. On the Secure World side, OP-TEE provides the following components: (1) a privileged layer (OP-TEE OS), executing at Arm secure EL1 level, and (2) a set of secure user space libraries (libutee) supporting Trusted Applications development. On the Normal World side, instead, OP-TEE provides the following components: (1) a Linux kernel TEE driver, (2) a client, including a Linux user space library (libteec, designed upon the GlobalPlatform TEE Client API), and (3) a user-space daemon (tee-supplicant) responsible for the remote services of the TEE OS.

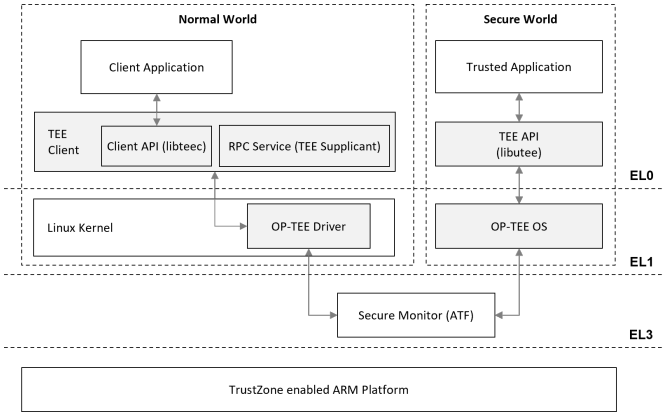

Figure 10. OP-TEE reference architecture, modified from [46].

As anticipated, the TEE can be deployed directly on smart edge devices or on a smart gateway. In both cases, an OP-TEE Trusted Application is used to implement the PE/PA logic. The interaction between the Portal Core Logic running in the REE and the PE/PA is then mediated by the OP-TEE client and the OP-TEE driver, leveraging the OP-TEE native API. The additional service modules leverage either capabilities that OP-TEE provides out of the box (e.g., Trusted Storage) or are implemented as custom Trusted Applications. To guarantee I/O access control, the Transferable Isolation Model [34] has been adopted, where the sensitive interfaces are available to the REE components, but they are protected by a component in the TEE (a PE/PA, from a Zero-Trust perspective), which mediates their access by managing specific protection mechanisms (a PEP).

5.3. Validation

This section illustrates the activities performed to evaluate the prototype, as deployed in the demonstration environment. The test scenario that has been implemented is a full-fledged end-to-end interaction with the remote maintenance infrastructure, which is represented in Figure 11 as a workflow. The figure illustrates the main actors of the test scenario, represented as vertical swim-lanes. Human actors are the Shop-floor Technician (starting the maintenance service request), the Remote Maintainer (requested for availability to perform the maintenance), and the Manager in Charge (responsible for authorizing the remote access). Non-human actors correspond to the main components of the proposed solution: the IAM System (in charge of the coordination of the authorization process, and of the release of the authorization token), the Automated Network Configuration Middleware (responsible for checking the compliance of the access request with the network security policies), the SDN Controller (dispatching the reconfiguration commands to the SDN appliances), the SDN Appliances (realizing the requested network reconfiguration and acting as network monitoring devices), the Gateway (divided into REE for the Front-end services and TEE for the access control enforcement), and the Edge Device (the target of remote maintenance).

The workflow illustrates the four main phases of the remote maintenance test scenario. The first phase, called Preliminary Authorizations, enforces coordination between the source of the maintenance request, the third-party service offer, and the manager in charge of the authorization. The phase can result in a failure, if approval or availability are not provided. Otherwise, it results in a token that is dispatched to ensure that remote access is granted. The second phase, called Access Grant, consists of the reconfiguration of the network and of the gateway access control to the edge device target resource. Network reconfiguration requires verification that the requested access is compliant with the network security policies. If successful, access is provided to the network node corresponding to the gateway. Then, further access control is enforced at the gateway level, where the maintainer uses the Gateway-REE to specify the requested resources for the maintenance activity. The Gateway-TEE checks for the compliance of the request with the security policies, and

then authorizes the request. The third phase, called Maintenance, is performed by the Remote Maintainer directly on the Edge Device, but the Gateway continuously checks the compliance of the requested operations and provides authentication. The third phase, called Cleanup, is in charge of reverting the network reconfiguration to the original state. The implemented scenario has been extensively tested throughout the three phases on the manufacturing infrastructure for demonstration, with a variety of parameters and settings.

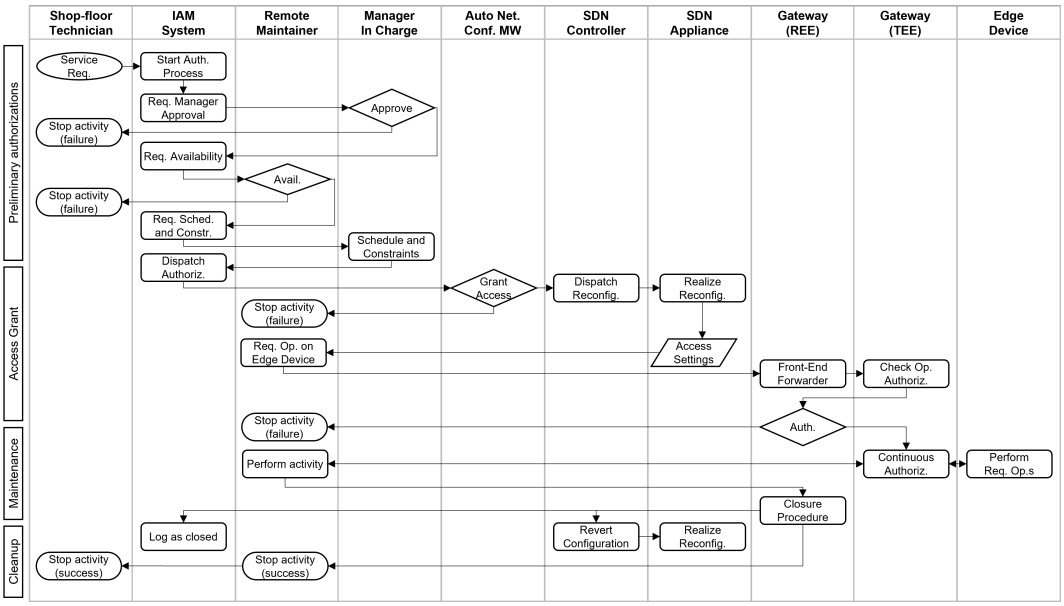

Figure 11. Industry 4.0 Remote Maintenance Scenario Workflow.

The following is a summary of the considerations in support of the satisfaction of the high-level requirements identified in Section 3.3:

SR1: The proposed solution limits access to a target network resource, and for a limited amount of time, it then restricts access to specific resources in the target equipment (memory region, service, parameters, and peripherals), enforcing security domains that are subject to confidentiality and integrity requirements. The coordination of PDPs guarantees the consistency of policies, supported by a methodology that is going to be discussed in Section 4.1.

SR2: Multiple PDPs and PEPs are deployed in the Support Infrastructure, with a possible distributed implementation of the Control Layer of the SDN platform; in addition, Secure Gateways support micro-segmentation, limiting the impact of a potential attack to a specific subset of equipment. A careful choice of SDN and Secure Gateway deployments can lead to an optimal trade-off between performance and resilience.

SR3: Access control granularity is designed to be scalable, using the two-layered approach; network resources are protected in a first layer, then once access is provided, the use of TEEs for the second-layer authorization enables for extremely fine-grained access control on resources (at the level of the memory region or peripherals), even in the case of legacy equipment.

SR4: SDN infrastructures support logging and detection in a native fashion, using Application Layer monitors that can be customized; the SDN architecture inherently provides detailed and end-to-end visibility on network traffic. In addition, TEE-based solutions can host secure storage and integrity monitoring services in the Secure World, guaranteeing tamper-proof logging.

6. Conclusions and Future Work

The current paper provides a comprehensive view of the research developed in the context of the COLLABS project [40] and the targeting of security solutions for collaborative

manufacturing infrastructures. A significant amount of work is foreseen to reinterpret several partial contributions into a unique solution architecture that is compliant with ZT principles. The two-layered model is believed to be capable of addressing fine-grained access control with greater scalability than the standard NIST reference architectures, and it is demonstrated how such a concept can be implemented with available and open-source technologies. The proposed methodology is only a first step towards a longer-term vision towards architecture security through powerful abstractions that are offered by modeling frameworks that were designed to manage the complexity of systems of systems integration. It also paves the ground for the automation of configuration tasks from a single source of truth model.

In terms of future work, there are several possible directions to develop. First, it would be interesting to further develop the two-layered model to have multiple intermediate authorization layers, addressing different levels of granularity, based on real applications scenarios. A second area of work is on the side of the implementation, where it would be interesting to identify what could be mature technologies for an industrial-strength implementation and demonstration. In this area, is also interesting to investigate and to implement standard interfaces to favor the adoption of alternative technologies by adhering to industrial standards. This aspect was partially addressed for TEEs by adopting the Global Platform abstraction, but there is more work to be conducted to achieve a mature two-layered ZT middleware. Another area of expansion is certainly the one related to automated analyses performed on the architectural model. It would be interesting to extend this work to facilitate the identification of spots in the architecture where ZT solutions can be inserted for mitigating high-ranked risks. Automation also facilitates life-cycle security management, which is an area that is worth investigating with model-based approaches. On the side of automated code generation, possible investigations would be both in the SDN Application Layer and in reusable TEE services and implementation patterns. Automation would reduce the burden of a user to focus mostly on the specification of the logic of PE/PA, and less on the technology-specific implementation details. Finally, a rather exploratory area would be to use and to integrate models coming from different organizations or from different layers of the same organization. In multi-tenant environments, it is common to have multiple teams managing the security of a portion of the overall infrastructure, with their own procedures and abstractions. Models could help to facilitate mutual understanding on security assumptions and guarantees, as well as a support for knowledge exchange concerning the many parts of a complex infrastructure.

Author Contributions: Conceptualization, F.F., D.M. and V.S.; methodology and formal analysis, V.S.; software, F.F. and D.M.; validation, F.F. and D.M.; writing—original draft preparation, F.F., D.M. and V.S.; writing—review and editing, F.F., D.M. and V.S.; supervision and funding acquisition, V.S. All authors have read and agreed to the published version of the manuscript.

Funding: This research has been founded by the European Union's Horizon 2020 Research and Innovation program under grant agreement No. 871518, a project named COLLABS [40].

Institutional Review Board Statement: Not applicable.

Informed Consent Statement: Not applicable.

Data Availability Statement: Research data is subject to COLLABS project [40] Consortium Agreement and can be requested by contacting the project coordinator.

Acknowledgments: We would like to acknowledge our colleagues Loris Dal Lago, Luca Manica, Greg Rice, and Luke Ryon for valuable insights, technical discussions, and feedback on the paper.

Conflicts of Interest: The authors declare no conflict of interest.

References

1. Li, S.; Xu, L.D.; Zhao, S. The internet of things: A survey. *Inf. Syst. Front.* **2015**, *17*, 243–259. [CrossRef]
2. Kitchin, R. *The Data Revolution: Big Data, Open Data, Data Infrastructures and Their Consequences*; Sage: Newcastle upon Tyne, UK, 2014.

3. World Trade Organization. *Big Data, Data Analytics, Artificial Intelligence and Machine Learning*; Technical Report the Role of Advanced Technologies in Cross-border Trade; WTO: Geneva, Switzerland, 2022.
4. IIC—IIRA—The Industrial Internet Reference Architecture, Industry IoT Consortium. Available online: https://www.iiconsortium.org/iira/ (accessed on 20 January 2023).
5. Buchheit, M.; Hirsch, F.; Martin, R.A.; Bemmel, V.; Espinosa, A.J.; Zarkout, B.; Hart, C.F.; Tseng, M. IIC—The Industrial Internet of Things, Trustworthiness Framework Foundations. Available online: https://www.iiconsortium.org/pdf/Trustworthiness_Framework_Foundations.pdf (accessed on 20 January 2023).
6. Rose, S.; Borchert, O.; Mitchell, S.; Connelly, S. *Zero Trust Architecture*; NIST SP 800-207; National Institute of Standards and Technology: Gaithersburg, MD, USA. Available online: https://csrc.nist.gov/publications/detail/sp/800-207/final (accessed on 20 January 2023).
7. Teerakanok, S.; Uehara, T.; Inomata, A. Migrating to zero trust architecture: Reviews and challenges. *Secur. Commun. Netw.* **2021**, *2021*, 9947347. [CrossRef]
8. He, Y.; Huang, D.; Chen, L.; Ni, Y.; Ma, X. A survey on zero trust architecture: Challenges and future trends. *Wirel. Commun. Mob. Comput.* **2022**, *2022*, 6476274. [CrossRef]
9. Milić, S.D.; Babić, B.M. Toward the future—Upgrading existing remote monitoring concepts to IIoT concepts. *IEEE Internet Things J.* **2020**, *7*, 11693–11700. [CrossRef]
10. Zhang, W.; Zhang, H.; Fang, L.; Liu, Z.; Ge, C. A secure revocable fine-grained access control and data sharing scheme for SCADA in IIoT systems. *IEEE Internet Things J.* **2021**, *9*, 1976–1984. [CrossRef]
11. Craggs, B.; Rashid, A.; Hankin, C.; Antrobus, R.; Şerban, O.; Thapen, N. A reference architecture for IIoT and industrial control systems testbeds. In Proceedings of the Living in the Internet of Things (IoT 2019), London, UK, 1–2 May 2019; pp. 1–8.
12. Pohl, F.; Schotten, H.D. Secure and scalable remote access tunnels for the IIoT: an assessment of openVPN and IPsec performance. In Proceedings of the European Conference on Service-Oriented and Cloud Computing, Oslo, Norway, 27–29 September 2017; pp. 83–90.
13. Hu, F.; Hao, Q.; Bao, K. A survey on software-defined network and openflow: From concept to implementation. *IEEE Commun. Surv. Tutor.* **2014**, *16*, 2181–2206. [CrossRef]
14. Sabt, M.; Achemlal, M.; Bouabdallah, A. Trusted Execution Environment: What It is, and What It is Not. In Proceedings of the 2015 IEEE TrustCom/BigDataSE/ISPA, Helsinki, Finland, 20–22 August 2015; Volume 1, pp. 57–64. [CrossRef]
15. DeCusatis, C.; Liengtiraphan, P.; Sager, A.; Pinelli, M. Implementing zero trust cloud networks with transport access control and first packet authentication. In Proceedings of the 2016 IEEE International Conference on Smart Cloud (SmartCloud), New York, NY, USA, 18–20 November 2016; pp. 5–10.
16. Asaithambi, S.; Ravi, L.; Kotb, H.; Milyani, A.H.; Azhari, A.A.; Nallusamy, S.; Varadarajan, V.; Vairavasundaram, S. An Energy-Efficient and Blockchain-Integrated Software Defined Network for the Industrial Internet of Things. *Sensors* **2022**, *22*, 7917. [CrossRef] [PubMed]
17. Basta, N.; Ikram, M.; Kaafar, M.A.; Walker, A. Towards a Zero-Trust Micro-segmentation Network Security Strategy: An Evaluation Framework. In Proceedings of the NOMS 2022—2022 IEEE/IFIP Network Operations and Management Symposium, Budapest, Hungary, 25–29 April 2022; pp. 1–7.
18. 5GZORRO—D2.4: Final Design of the 5GZORRO Platform for Security & Trust. Available online: https://www.5gzorro.eu/wp-content/uploads/2022/05/5GZORRO_D2.4_v1.0-Final_withWM.pdf (accessed on 12 December 2022).
19. Papakonstantinou, N.; Van Bossuyt, D.L.; Linnosmaa, J.; Hale, B.; O'Halloran, B. A zero trust hybrid security and safety risk analysis method. *J. Comput. Inf. Sci. Eng.* **2021**, *21*, 050907. [CrossRef]
20. RTCA DO-326—Airworthiness Security Process Specification | Engineering360. Available online: https://standards.globalspec.com/std/9869201/RTCA%20DO-326 (accessed on 13 December 2022).
21. Hozdić, E. Smart factory for industry 4.0: A review. *Int. J. Mod. Manuf. Technol.* **2015**, *7*, 28–35.
22. Frost, A.; Report, S. Navigating through Operational Turbulence. Available online: https://www.frost.com/wp-content/uploads/2020/01/White-Paper-Navigating-through-operational-turbulence.pdf (accessed on 20 January 2023).
23. Schultz, M. Fast aircraft turnaround enabled by reliable passenger boarding. *Aerospace* **2018**, *5*, 8. [CrossRef]
24. Li, S.; Yang, Y.; Yang, L.; Su, H.; Zhang, G.; Wang, J. Civil aircraft big data platform. In Proceedings of the 2017 IEEE 11th International Conference on Semantic Computing (ICSC), San Diego, CA, USA, 30 January–1 February 2017; pp. 328–333.
25. Federici, F.; Tonelli, C.; Le Cam, M.; Torchio, M.; Larsen, D. Design and validation of scalable PHM solutions for aerospace onboard systems. *PHM Soc. Eur. Conf.* **2022**, *7*, 126–135. [CrossRef]
26. Ryon, L.; Martintoni, D. Field Loadable Software Confidentiality Protection. In Proceedings of the 2022 IEEE/AIAA 41st Digital Avionics Systems Conference (DASC), Portsmouth, VA, USA, 18–22 September 2022; pp. 1–6.
27. Rocchetto, M.; Tippenhauer, N.O. On Attacker Models and Profiles for Cyber-Physical Systems. In *Proceedings of the Computer Security—ESORICS*; Askoxylakis, I., Ioannidis, S., Katsikas, S., Meadows, C., Eds.; Lecture Notes in Computer Science; Springer International Publishing: Cham, Switzerland, 2016; pp. 427–449. [CrossRef]
28. Shostack, A. *Threat Modeling: Designing for Security*; John Wiley & Sons: Hoboken, NJ, USA, 2014.
29. Kindervag, J. *Build Security into Your Network's DNA: The Zero Trust Network Architecture*; Forrester Research Inc.: Cambridge, MA, USA, 2010; Volume 27.

30. Reference Architectural Model Industrie 4.0 (RAMI4.0)—An Introduction. Available online: https://www.plattform-i40.de/IP/Redaktion/EN/Downloads/Publikation/rami40-an-introduction.html (accessed on 12 December 2022).
31. Nakagawa, E.Y.; Antonino, P.O.; Schnicke, F.; Capilla, R.; Kuhn, T.; Liggesmeyer, P. Industry 4.0 reference architectures: State of the art and future trends. *Comput. Ind. Eng.* **2021**, *156*, 107241. [CrossRef]
32. Li, S.; Iqbal, M.; Saxena, N. Future Industry Internet of Things with Zero-trust Security. *Inf. Syst. Front.* **2022**, 1–14. [CrossRef]
33. Zolotová, I.; Bundzel, M.; Lojka, T. Industry IoT gateway for cloud connectivity. In Proceedings of the IFIP International Conference on Advances in Production Management Systems, Tokyo, Japan, 7–9 September 2015; pp. 59–66.
34. Global Platform—TEE System Architecture v1.3—GPD_SPE_009 GlobalPlatform. Available online: https://globalplatform.org/specs-library/tee-system-architecture/ (accessed on 12 December 2022).
35. Køien, G.M. Zero-Trust Principles for Legacy Components. *Wirel. Pers. Commun.* **2021**, *121*, 1169–1186. [CrossRef]
36. Lago, L.D.; Federici, F.; Martintoni, D.; Senni, V. Risk-driven Model-based Architecture Design for Secure Information Flows in Manufacturing Infrastructures. In Proceedings of the 19th International Conference on Security and Cryptography, SECRYPT 2022, Lisbon, Portugal, 11–13 July 2022; di Vimercati, S.D.C., Samarati, P., Eds.; Scitepress: Setúbal, Portugal, 2022; pp. 499–506. [CrossRef]
37. Friedenthal, S.; Moore, A.; Steiner, R. *A Practical Guide to SysML: The Systems Modeling Language*; Morgan Kaufmann: Burlington, MA, USA, 2014.
38. Rocchetto, M.; Ferrari, A.; Senni, V. Challenges and Opportunities for Model-Based Security Risk Assessment of Cyber-Physical Systems. In *Resilience of Cyber-Physical Systems*; Flammini, F., Ed.; Advanced Sciences and Technologies for Security Applications; Springer: Cham, Switzerland, 2019. [CrossRef]
39. Ngo, C.; Demchenko, Y.; de Laat, C. Multi-tenant attribute-based access control for cloud infrastructure services. *J. Inf. Secur. Appl.* **2016**, *27*, 65–84. [CrossRef]
40. A Comprehensive Cyber-Intelligence Framework for Resilient coLLABorative Manufacturing Systems | COLLABS Project | Fact Sheet | H2020 | CORDIS | European Commission. Available online: https://cordis.europa.eu/project/id/871518 (accessed on 12 December 2022).
41. Floodlight Controller—Confluence. Available online: https://floodlight.atlassian.net/wiki/spaces/floodlightcontroller/overview (accessed on 12 December 2022).
42. Open vSwitch. Available online: https://www.openvswitch.org (accessed on 12 December 2022).
43. Kasinathan, P.; Martintoni, D.; Hofmann, B.; Senni, V.; Wimmer, M. Secure Remote Maintenance via Workflow-Driven Security Framework. In Proceedings of the 2021 IEEE International Conference on Blockchain (Blockchain), Melbourne, Australia, 6–8 December 2021; pp. 29–37.
44. Pinto, S.; Santos, N. Demystifying arm trustzone: A comprehensive survey. *ACM Comput. Surv. (CSUR)* **2019**, *51*, 1–36. [CrossRef]
45. ARM Trusted Firmware—A (TF-A), Linaro. Available online: https://www.trustedfirmware.org/projects/tf-a/ (accessed on 12 December 2022).
46. Open Portable Trusted Execution Environment—OP-TEE. Available online: https://www.op-tee.org/ (accessed on 12 December 2022).

Disclaimer/Publisher's Note: The statements, opinions and data contained in all publications are solely those of the individual author(s) and contributor(s) and not of MDPI and/or the editor(s). MDPI and/or the editor(s) disclaim responsibility for any injury to people or property resulting from any ideas, methods, instructions or products referred to in the content.